PrediCare — Dossier de cadrage stratégique

TCO, ROI, RGPD, EU AI Act, équité, sécurité et cache sémantique

Équipe PrediCare — Mirado, Jerry, Cherica

Version 1.0 — 20 octobre 2026

Document de travail remis au jury. Les chiffres sont datés, mesurés sur la pile de démonstration et traçables dans les fichiers cités. Les prix d'hébergement sont des hypothèses explicitement signalées.

Table des matières

Note de lecture

Synthèse pour le jury

1. TCO et ROI

- 1.1 Méthode et périmètre
- 1.2 Coût d’infrastructure
- 1.3 Coût des tokens
- 1.4 Sauvegarde et restauration
- 1.5 TCO consolidé
- 1.6 ROI
- 1.7 Leviers FinOps
- 1.8 Limites

2. RGPD

- 2.1 Rôles et gouvernance
- 2.2 Cartographie des traitements
- 2.3 Bases légales
- 2.4 Minimisation et pseudonymisation
- 2.5 Durées de conservation
- 2.6 Droits des personnes
- 2.7 Sous-traitants et transferts
- 2.8 AIPD (analyse d’impact)
- 2.9 Violations et registre

3. EU AI Act

- 3.1 Classement et rôle
- 3.2 Pratiques interdites
- 3.3 Grille des obligations
- 3.4 Supervision humaine et transparence
- 3.5 LLM et GPAI
- 3.6 Feuille de route conformité
- 3.7 Conclusion

4. Audit d’équité

- 4.1 Méthode
- 4.2 Résultats
- 4.3 Lecture
- 4.4 Mesures
- 4.5 Risque résiduel

5. Sécurité

- 5.1 Modèle de menace
- 5.2 Authentification et habilitations
- 5.3 Protection des données
- 5.4 Sécurité du RAG
- 5.5 Réseau et chaîne d’approvisionnement
- 5.6 Audit et supervision
- 5.7 Preuves de test
- 5.8 Écarts et plan de durcissement

6. Cache sémantique et FinOps

6.1 Mécanisme et garde-fous

6.2 Mesure

6.3 Modèle de coût

6.4 Limites

6.5 Recommandations

Annexes

A. Index des preuves

B. Hypothèses et taux

C. Glossaire

D. Checklist pour le jury

Note de lecture

Ce dossier répond à la phase 10.3 du plan d'action. Il ne remplace pas les rapports techniques : il les assemble et les traduit en décisions de cadrage. Chaque chiffre est suivi de sa source, d'une commande ou d'un fichier versionné.

Trois règles de lecture :

1. **Mesuré n'est pas estimé.** Les volumes, latences, coûts de tokens, tailles de sauvegarde et résultats du modèle viennent d'exécutions réelles sur la pile de démonstration. Les prix d'hébergement sont des hypothèses datées, signalées comme telles.
2. **Le périmètre est la démonstration, pas la production.** Les écarts de conformité sont nommés au lieu d'être masqués : c'est ce qui rend le dossier utile à un jury et à une mise en production.
3. **Les montants métier sont en ariary (MGA).** Le taux de conversion de travail est de **1 EUR = 5 000 MGA** ; il doit être actualisé le jour de la soutenance. Les ratios (ROI, coût par requête) ne dépendent pas de ce taux.

Synthèse pour le jury

PrediCare est une plateforme d'assurance santé qui réunit trois flux : détection de fraude explicable, assistant documentaire augmenté (RAG) et pilotage décisionnel. Le dossier porte sur les deux premiers, et sur les conditions de leur exploitation.

Les six chiffres à retenir

Indicateur	Valeur mesurée	Source
ROC-AUC du modèle de fraude (v2, seuil 0,2876)	**0,9500**	`reports/modele_v2.md`
Rappel au seuil retenu	**87,0 %**	`reports/modele_v2.md`
Économie de coût de contrôle sur le jeu de test	**22 656 000 MGA**	`reports/modele_v2.md`
Fidélité / citation / exactitude du RAG	**30/30, 20/20, 26/26**	`reports/eval_rag_2026-10-19_5.json`
Coût LLM par requête RAG	**0,00064 USD** (~0,00059 EUR)	`apps/api-rag/README.md`, moyenne 30 questions
Tests automatisés	**659 passés, 18 ignorés**	`make test`, 20/10/2026

La décision de cadrage

Le système est classé **haut risque par précaution** au sens du règlement (UE) 2024/1689 (AI Act) : il produit un score qui oriente une décision de prise en charge d'une personne, même si la décision finale reste humaine. Le dossier mappe les obligations des articles 9 à 15, 17, 43, 49, 72 et 73, et identifie les preuves déjà disponibles et les écarts à combler avant une mise en production.

Les trois écarts à traiter avant production

1. **Politique de conservation et droits des personnes** : les durées de conservation ne sont pas encore formalisées, et l'effacement n'est pas propagé automatiquement aux données pseudonymisées.
2. **Durcissement de l'exploitation** : TLS de bout en bout, chiffrement des sauvegardes, rotation des clés, journalisation des connexions et test d'intrusion restent à faire. Deux alertes Dependabot modérées sont ouvertes.
3. **Dossier AI Act formel** : registre des risques, documentation Annexe IV, évaluation de conformité, marquage CE et enregistrement ne sont pas encore produits. La présente note est la trame, pas la certification.

Ce que le dossier ne prétend pas

Le modèle n'est pas un détecteur de fraude universel : il est entraîné sur une population synthétique de 84 593 factures et mesure un rappel de 87,0 %, sous l'objectif de 90 %. Les économies sont des **coûts de contrôle évités** par rapport à un scénario « tout contrôler », pas de la fraude recouvrée. Le RAG répond sur les contrats et l'historique de l'assuré, pas sur l'ensemble du droit de la santé.

1. TCO et ROI

1.1 Méthode et périmètre

Le TCO couvre trois postes : infrastructure, tokens LLM et sauvegarde. Le ROI compare le coût de contrôle du modèle au scénario « toutes les factures sont contrôlées ». Les deux sont calculés sur les données mesurées, puis projetés sur un volume annuel explicitement signalé.

Élément	Nature	Source
Mémoire de la pile	Mesuré	`make up` ~4,5 Go ; `make up-all` ~6,5 Go (`README.md`)
Base de données	Mesuré	110 Mo, 84 608 factures, 5 528 prédictions (`psql`)
Sauvegarde compressée	Mesuré	12 659 763 octets pour une base de 110 Mo (`pg_dump`)
Tokens RAG	Mesuré	111 742 tokens pour 30 questions (`eval_rag_2026-10-19_5.json`)
Coût par requête	Mesuré	0,00064 USD (`apps/api-rag/README.md` , moyenne 30 questions)
Prix VPS	Hypothèse datée	8,49 €/mois HT pour 4 vCPU / 8 Go / 80 Go (comparateur CostGoat, oct. 2026)
Coût d'un faux positif / faux négatif	Hypothèse métier du projet	3 000 / 30 000 MGA (`reports/strategies_v1.md`)
Taux de conversion	Convention	1 EUR = 5 000 MGA

1.2 Coût d'infrastructure

La pile complète tient dans **6,5 Go** de mémoire ; le socle `make up` tourne dans **4,5 Go**. Une machine de démonstration 8 Go / 4 vCPU / 80 Go suffit donc pour la démo, avec une marge étroite si l'on ajoute les overlays. Le scénario de base retient ce dimensionnement.

Poste	Base	Stress	Commentaire
VPS 4 vCPU / 8 Go / 80 Go	8,49 €/mois	12,00 €/mois	Prix public indicatif, à remplacer par un devis
Coût annuel	**101,88 €**	**144,00 €**	12 mois
Sauvegarde (177 Mo en base, 1 Go en stress, 14 jours)	0,02 €/an	0,12 €/an	Stockage objet à 0,01 €/Go/mois
Sous-total infrastructure	**101,90 €/an**	**144,12 €/an**	

La machine de démonstration de l'équipe coûte **0 €** : le scénario ci-dessus est le coût de l'hébergement si la plateforme est sortie du poste de développement. Il inclut l'OS, le reverse proxy et les volumes, pas les postes de travail des utilisateurs.

1.3 Coût des tokens

Le RAG utilise `gpt-4o-mini`. Sur les 30 questions de référence, la consommation mesurée est de **111 742 tokens** (108 501 en entrée, 3 241 en sortie), soit **3 725 tokens par question**. Le prompt domine : 97 %

des tokens sont de l'entrée.

Mesure	Valeur	Source
Tokens / question	3 725	`eval_rag_2026-10-19_5.json`
Coût au tarif du service (0,15 / 0,60 USD par million)	**0,00064 USD** (~0,00059 EUR)	`apps/api-rag/README.md`, moyenne 30 questions
Coût conservateur (0,60 USD/M uniforme)	0,00223 USD	`eval_rag_2026-10-19_5.json`
Coût de l'évaluation (30 questions)	0,0670 USD	même fichier

Le tarif conservateur est utilisé pour les scénarios de stress : il surestime le coût d'environ 3,5 fois, mais il ne dépend d'aucune hypothèse de répartition entrée/sortie.

Volume	Base (0,00064 USD/q)	Conservateur (0,00223 USD/q)
1 000 questions/mois	7,68 USD/an (~7,07 €)	26,82 USD/an (~24,67 €)
10 000 questions/mois	76,80 USD/an (~70,66 €)	268,20 USD/an (~246,74 €)

1.4 Sauvegarde et restauration

La sauvegarde est un `pg_dump` compressé en gzip, exécuté par `supercronic`, conservé **14 jours** dans le volume `backups`. Une sauvegarde de la base de démonstration pèse **12,66 Mo** ; 14 sauvegardes représentent **177 Mo**.

Élément	Valeur
Taille de la base	110 Mo
Taille d'une sauvegarde compressée	12,66 Mo
Rétention	14 jours
Volume conservé	~177 Mo
Coût de stockage	< 0,12 €/an

La procédure de restauration est documentée (`db/backup/README.md`, cible `make restore`). Elle n'a pas été rejouée dans ce dossier : le test de restauration complet reste une action de recette avant production. La sauvegarde n'est pas chiffrée aujourd'hui : c'est un écart identifié en 5.8.

1.5 TCO consolidé

Poste	Base	Stress	Conservateur
Infrastructure	101,88 €	144,00 €	144,00 €
Sauvegarde	0,02 €	0,12 €	0,12 €
Tokens RAG	7,07 €	70,66 €	246,74 €
Total annuel	**108,97 €**	**214,78 €**	**390,86 €**
Total en MGA	**544 850 MGA**	**1 073 900 MGA**	**1 954 300 MGA**

Base : 1 000 questions/mois et VPS à 8,49 €. Stress : 10 000 questions/mois et VPS à 12 €. Conservateur : 10 000 questions/mois au tarif uniforme de 0,60 USD par million de tokens, qui surestime le coût d'environ 3,5 fois.

Le poste dominant est l'infrastructure, pas le LLM. À 1 000 questions par mois, les tokens représentent 6,5 % du TCO ; à 10 000 questions, 33 %. Le cache sémantique (partie 6) est donc un levier réel, mais il ne compensera jamais une infrastructure mal dimensionnée.

1.6 ROI

Le modèle v2, au seuil 0,2876, produit la matrice de confusion suivante sur le jeu de test (10 086 factures, 878 fraudes, taux de fraude 8,7 %). Le registre conserve v1 et v2 ; les métriques exposées par `/api/inference/modele` pour la version chargée sont identiques à celles du rapport v2.

	Fraude réelle	Non-fraude réelle
Alerte (score ≥ seuil)	764 (VP)	516 (FP)
Pas d'alerte	114 (FN)	8 692 (VN)

Le coût métier est la somme des contrôles inutiles et des fraudes manquées :

- faux positif : 3 000 MGA (coût d'un contrôle) ;
- faux négatif : 30 000 MGA (fraude non détectée).

Scénario	Calcul	Coût
Au seuil 0,2876	516 × 3 000 + 114 × 30 000	**4 968 000 MGA**
Tout contrôler	9 208 × 3 000	27 624 000 MGA
Économie	27 624 000 − 4 968 000	**22 656 000 MGA**

L'économie est un **coût de contrôle évité**, pas une fraude recouvrée. Elle mesure ce que la plateforme fait gagner par rapport à un contrôle exhaustif, à qualité de détection égale.

Projection annuelle. Le jeu de données contient 84 593 factures ; le jeu de test en contient 10 086, soit un facteur 8,387. À taux de fraude et à coût unitaire constants, l'économie annuelle serait de **190,0 millions MGA** (22 656 000 × 8,387), soit **2 246 MGA par facture**. C'est une extrapolation, pas une mesure de production.

Scénario	Factures/an	Économie	TCO	ROI net	Ratio
Jeu de test mesuré	10 086	22,66 M MGA	0,545 M MGA	22,11 M MGA	**41,6×**
Annuel à volume constant	84 593	190,02 M MGA	0,545 M MGA	189,48 M MGA	**348,8×**
Prudent : 50 % de l'économie, TCO stress	84 593	95,01 M MGA	1,074 M MGA	93,94 M MGA	**88,5×**

Le retour sur coût est immédiat à l'échelle du jeu de test : le TCO annuel représente 2,4 % de l'économie mesurée. La prudence reste de mise : le ROI dépend du taux de fraude réel, du coût des contrôles et de la qualité de la décision humaine.

1.7 Leviers FinOps

Levier	Effet mesuré ou attendu	Coût
Cache sémantique	0 token, 0 ms de LLM sur un hit ; 10,48 s et 0,00064 € évités sur 2 hits	Déjà actif

Levier	Effet mesuré ou attendu	Coût
Réduire `RAG_TOP_K`	Moins de tokens d’entrée ; à arbitrer avec la fidélité	Réglage
Réduire `SESSION_MAX_TURNS`	Moins d’historique rejoué ; protège la latence	Réglage
Modèle `gpt-4o-mini`	Coût maîtrisé ; pas de modèle plus gros sans mesure	Déjà actif
Plafond de débit Traefik	60 req/min, burst 120 : protège le quota LLM	Déjà actif
Alerte `predicare_llm_cost_usd_total`	Détecte une dérive de consommation	À configurer

Le prompt domine le coût. Toute action qui réduit le nombre de passages récupérés ou l’historique rejoué a plus d’effet que le choix du modèle.

1.8 Limites

- Les prix d’hébergement sont des hypothèses, pas des devis.
- L’extrapolation annuelle suppose un taux de fraude et un coût unitaire identiques à ceux du jeu de test.
- Le modèle n’est pas entraîné sur des factures de production : le rappel de 87,0 % est une mesure sur jeu synthétique.
- Le TCO n’inclut ni le temps de développement, ni le temps de supervision humaine, ni les coûts de mise en conformité (audit, conseil juridique).
- Les coûts de tokens sont ceux du RAG ; la détection de fraude n’appelle pas de LLM à l’inférence.

2. RGPD

2.1 Rôles et gouvernance

Acteur	Rôle RGPD	Commentaire
Assureur (client)	Responsable de traitement	Détermine les finalités et les moyens
Équipe PrediCare	Sous-traitant / fournisseur	Héberge et maintient la plateforme
OpenAI	Sous-traitant ultérieur	Reçoit les questions et extraits pseudonymisés
Slack / e-mail	Sous-traitants de notification	Reçoivent référence de facture, score, SHAP
DPO	À désigner	Point de contact, registre, AIPD

La gouvernance n'est pas encore formalisée : le registre des traitements, la désignation du DPO et les contrats de sous-traitance sont des actions de production. Le dossier fournit la matière pour les établir.

2.2 Cartographie des traitements

Traitement	Personnes	Données	Finalité	Base légale (à confirmer)	Conservation
Identité assuré	Assurés	Nom, coordonnées, date de naissance	Gestion du contrat	Exécution du contrat (art. 6.1.b)	Durée du contrat + prescription
Facturation / remboursement	Assurés, prestataires	Actes, montants, dates, santé	Prise en charge	Exécution du contrat ; obligation légale	10 ans (proposition)
Détection de fraude	Assurés, prestataires	Factures pseudonymisées, score, SHAP	Prévention de la fraude	Intérêt légitime (art. 6.1.f) ; art. 9.2.f pour la santé	3 ans (proposition)
Assistant RAG	Assurés	Question, historique, extraits de contrat	Information contractuelle	Exécution du contrat	Session 1 h ; logs 30 j
Audit et décisions	Gestionnaires, administrateurs	Acteur, rôle, action, décision	Traçabilité, conformité	Obligation légale (art. 6.1.c)	5 ans (proposition)
Sauvegardes	Tous	Copie de la base	Continuité	Intérêt légitime	14 jours

La colonne « conservation » est une **proposition** : elle n'est pas encore appliquée par le code. C'est l'écart principal de la partie RGPD.

2.3 Bases légales

La base légale doit être validée par le DPO de l'assureur. Trois points sont sensibles :

- **Données de santé** : les factures et les actes révèlent l'état de santé. L'article 9.2.f (constatation, exercice ou défense d'un droit en justice) ou l'article 9.2.h (médecine) doivent être explicitement retenus ; l'intérêt légitime de l'article 6 ne suffit pas à lui seul pour la santé.
- **Détection de fraude** : l'intérêt légitime est plausible, mais il exige une mise en balance et une information claire des personnes. Le score ne doit pas produire un effet juridique automatique.

- **Assistant RAG** : les questions peuvent contenir des données de santé. La minimisation (pas de nom, pas de détail inutile) et la durée de session courte sont des mesures de protection.

2.4 Minimisation et pseudonymisation

Le projet applique une règle structurante : **les noms et coordonnées n'existent que dans une table chiffrée isolée**. Partout ailleurs, on manipule un pseudonyme non réversible.

Mesure	Implémentation	Preuve
Chiffrement des identités	Fernet (AES-128-CBC + HMAC), clé dans l'environnement	`packages/predicare-core/src/predicare/crypto.py`
Pseudonyme stable	HMAC-SHA256 avec `APP_SECRET_KEY`	même fichier
Aucun nom dans les factures	`core.facture` ne porte que `assure_id`	schéma `db/migrations/versions/0001_initial_schema.py`
Cloisonnement du cache RAG	clé `assure_id` ou `user:{subject}`	`apps/api-rag/src/predicare_rag_api/main.py`
Filtre SQL par assure	compte en lecture seule + paramètre lié	`apps/api-rag/src/predicare_rag_api/sql_tool.py`
Journal d'audit	acteur, rôle, action, cible, détails	`audit.journal`

La clé d'identité n'est ni en base ni dans le code. Elle est générée par `make secrets` et stockée dans `.env`, ignoré par Git. La rotation de clé n'est pas automatisée : c'est un écart de production.

2.5 Durées de conservation

Aucune purge automatique des **données métier** n'est implémentée : les factures, prédictions et audits restent en base jusqu'à une action manuelle. Les sessions Redis expirent (TTL 1 h) et les sauvegardes sont rotationnées à 14 jours, mais ce sont les seules purges automatiques.

Donnée	Aujourd'hui	Proposition
Identités chiffrées	Indéfini	Durée du contrat + prescription
Factures / prédictions	Indéfini	3 ans pour les prédictions, 10 ans pour les factures
Décisions et audit	Indéfini	5 ans
Sessions RAG	Redis, TTL 1 h	1 h
Logs applicatifs	Selon le volume Docker	30 jours
Sauvegardes	14 jours	14 jours

Action : écrire une politique de conservation, ajouter des jobs de purge et un test qui vérifie qu'une donnée expirée n'est plus servie.

2.6 Droits des personnes

Droit	État	Écart
Accès	Les écrans affichent les données de l'assuré	Pas d'export structuré « copie des données »

Droit	État	Écart
Rectification	Les identités sont modifiables en base	Pas d'écran de rectification
Effacement	Suppression manuelle de l'identité en base	Pas de propagation aux factures, prédictions, audits, sauvegardes
Opposition	Non traité	À définir pour la prospection (hors périmètre)
Portabilité	Non traité	À définir
Limitation	Non traité	À définir

L'effacement est le point le plus délicat : supprimer la ligne d'identité rend le pseudonyme non ré-identifiable, mais les factures et prédictions restent. Une procédure doit décider si l'on conserve les données pseudonymisées pour l'audit (obligation légale) ou si on les supprime.

2.7 Sous-traitants et transferts

Destinataire	Données reçues	Localisation	Mesure
OpenAI	Question, extraits de contrats, historique	États-Unis (probable)	DPA, clauses contractuelles types, minimisation
Slack	Référence facture, score, SHAP	États-Unis	Workspace privé, DPA
Mailpit (dev)	E-mail de notification	Local	Développement uniquement
Hébergeur	Base, sauvegardes	À choisir	DPA, chiffrement, localisation UE

Les transferts hors UE ne sont pas documentés aujourd'hui. Avant production, il faut vérifier la localisation du fournisseur LLM, signer les clauses contractuelles types et mettre à jour le registre.

2.8 AIPD (analyse d'impact)

Le traitement est susceptible d'engendrer un risque élevé : données de santé, scoring, décision financière, population potentiellement vulnérable. Une AIPD est donc requise avant production.

Risque	Gravité	Mesures existantes	Risque résiduel
Faux positif → retard de remboursement	Moyenne	Décision humaine, commentaire, audit	Moyen
Biais défavorable à un segment	Moyenne	Audit d'équité, supervision	Moyen
Ré-identification	Élevée	Chiffrement, pseudonymisation, cloisonnement	Faible
Fuite vers le LLM	Élevée	Minimisation, pas de noms, DPA à signer	Moyen
Injection de prompt	Moyenne	Filtre, séparation instruction/donnée, SQL lecture seule	Faible
Accès indu du professionnel	Moyenne	RBAC, mais filtre prestataire absent	**Élevé**
Sauvegarde non chiffrée	Moyenne	Volume dédié, accès restreint	Moyen

L’accès indu du professionnel (G7 de `docs/analyse_front_vs_cdc.md`) est le risque résiduel le plus visible : un professionnel voit toutes les factures pseudonymisées, pas seulement les siennes. La correction est classée P0 dans l’analyse front.

2.9 Violations et registre

- **Notification** : la procédure de notification sous 72 h n’est pas écrite. Les journaux et l’audit fournissent la matière, mais il manque un runbook.
- **Registre des traitements** : ce dossier en est la première version ; il doit être repris dans l’outil du DPO.
- **Sous-traitants** : la liste est connue (OpenAI, Slack, hébergeur), les contrats restent à signer.
- **Formation** : les utilisateurs doivent savoir que le score est une aide, pas un verdict.

3. EU AI Act

3.1 Classement et rôle

Le règlement (UE) 2024/1689 encadre les systèmes d'IA par niveau de risque. Le classement retenu est **haut risque par précaution**.

Question	Réponse
Le système est-il dans une pratique interdite (art. 5) ?	Non : pas de scoring social, pas de manipulation, pas de biométrie
Est-il listé à l'annexe III ?	Pas explicitement : la détection de fraude n'est pas « tarification » ni « évaluation de solvabilité ». Mais le score oriente une décision de prise en charge d'une personne
Classement prudent	**Haut risque** (annexe III, 5 b, par analogie)
Rôle de l'équipe	Fournisseur du système ; l'assureur sera déployeur
Décision finale	Humaine : le gestionnaire valide, rejette ou demande une pièce

Le classement doit être confirmé par un avis juridique avant production. Si le score ne sert qu'à **prioriser un contrôle** sans effet sur le droit au remboursement, un classement « risque limité » avec obligations de transparence pourrait être défendu. Le dossier retient la lecture prudente.

3.2 Pratiques interdites

Pratique (art. 5)	Présente ?	Preuve
Manipulation / tromperie	Non	Le score est expliqué, le SHAP est affiché
Exploitation d'une vulnérabilité	Non	Pas de ciblage de personnes vulnérables
Scoring social	Non	Pas de notation de comportement social
Police prédictive	Non	Pas de données pénales
Biométrie / reconnaissance faciale	Non	Aucune image, aucune biométrie
Extraction non ciblée de données	Non	Le RAG lit des contrats et l'historique de l'assuré

3.3 Grille des obligations

Obligation	Article	Preuve disponible	Écart
Système de gestion des risques	9	Rapports modèle et équité, dérive, tests	Registre des risques formel à créer
Gouvernance des données	10	84 593 factures, 0 manquante, 0 doublon exact, empreinte SHA-256	Data sheet Annexe IV à formaliser
Documentation technique	11	Ce dossier, `README`, ADR, model card, évals	Trame Annexe IV à produire

Obligation	Article	Preuve disponible	Écart
Journalisation	12	`audit.journal`, `audit.decision_gestionnaire`, `ml.modele_version`, `ml.rapport_derive`	Connexions et actions admin non toutes journalisées
Transparence	13	SHAP, seuil, version, sources RAG	Mention « assistant IA » à ajouter dans l'interface
Supervision humaine	14	Route `POST /alertes/decision`, commentaire, audit	Procédure d'escalade à écrire
Exactitude, robustesse, cybersécurité	15	ROC-AUC 0,95, rappel 87 %, 659 tests, RBAC, SQL lecture seule	Test d'intrusion, TLS, sauvegardes chiffrées
Système de management de la qualité	17	CI, revue, tests, versionnement, ADR	QMS formel à documenter
Évaluation de conformité	43	Auto-évaluation interne possible (annexe VI)	Non réalisée
Marquage CE et enregistrement	48, 49	—	À faire avant mise sur le marché
Surveillance après commercialisation	72	Worker de dérive, Prometheus, Grafana, alertes	Plan de surveillance à écrire
Incidents graves	73	Logs, audit, sauvegardes	Procédure de notification à écrire

3.4 Supervision humaine et transparence

La supervision humaine est réelle, pas décorative :

1. le modèle produit un score et un rapport SHAP ;
2. la facture arrive dans la file du gestionnaire ;
3. le gestionnaire ouvre le détail, lit les contributions et décide ;
4. la décision est écrite dans `audit.decision_gestionnaire` via `POST /api/core/alertes/decision`, avec l'acteur, l'horodatage et un commentaire.
5. la facture sort de la file.

Le score ne rejette jamais automatiquement une facture. Le seuil est modifiable à chaud, mais le changement est tracé (`audit.parametre`).

Transparence : l'interface affiche le score, le seuil, la version du modèle et les contributions SHAP. Il manque une mention explicite « réponse générée par un assistant IA » sur l'écran RAG, et une explication vulgarisée du score pour l'assuré. Ce sont des actions de production.

3.5 LLM et GPAI

Le RAG utilise un modèle d'IA à usage général (`gpt-4o-mini`) via API. Le fournisseur du modèle porte les obligations GPAI (art. 53 et suivants) ; en tant que déployeur, l'équipe doit :

- documenter le modèle et sa version dans le registre ;
- vérifier les conditions d'utilisation et le DPA ;
- ne pas envoyer de données non minimisées ;
- prévoir un repli si le fournisseur change ou ferme l'accès ;
- surveiller le coût et la latence.

Le modèle de fraude est un modèle supervisé entraîné par l'équipe : il relève du système d'IA haut risque, pas des GPAI.

3.6 Feuille de route conformité

Étape	Livrable	Responsable	Échéance
1	Avis juridique sur le classement	Juriste / DPO	Avant production
2	Registre des risques (art. 9)	Mirado + Jerry	Avant production
3	Documentation Annexe IV	Mirado	Avant production
4	QMS et procédures	Jerry	Avant production
5	AIPD et registre RGPD	DPO	Avant production
6	Tests de robustesse et intrusion	Jerry	Avant production
7	Évaluation de conformité, CE, enregistrement	Direction	Avant mise sur le marché
8	Plan de surveillance et procédure d'incident	Jerry	Avant production
9	Mention IA et information des utilisateurs	Cherica	Avant démo finale

3.7 Conclusion

Le système est **conforme par conception** sur les points démontrables : décision humaine, explicabilité, journalisation, minimisation, tests, dérive. Il n'est **pas certifié** : l'évaluation de conformité, le marquage CE, l'enregistrement et le QMS formel restent à produire. Le dossier de cadrage est la base de ces livrables, pas leur substitut.

4. Audit d’équité

4.1 Méthode

L’audit porte sur le jeu de test du modèle v2 : **10 086 factures**, 878 fraudes réelles (8,7 %). Le rappel et la précision sont calculés par segment. Un segment de petite taille est signalé : un écart sur 80 factures n’a pas la portée d’un écart sur 3 000.

4.2 Résultats

Par tranche d’âge

Segment	n	Rappel	Précision
0–17	3 378	0,8902	0,6651
18–29	927	0,8929	0,5639
30–49	2 638	0,8465	0,5778
50–64	3 009	0,8559	0,5460
65+	134	0,8889	0,5333

Par niveau de tarif

Segment	n	Rappel	Précision
ÉLEVÉ	2 623	0,9214	0,4741
RAISONNABLE	6 593	0,8489	0,6914
TRÈS ÉLEVÉ	870	0,7922	0,8841

Par type de prestataire

Segment	n	Rappel	Précision
CABINET_DENTAIRE	202	0,9722	0,6481
CABINET_GENERALISTE	2 518	**0,7622**	0,4941
CABINET_SPECIALISTE	535	0,9667	0,2358
CENTRE_IMAGERIE	205	0,8571	0,9474
CLINIQUE	1 922	0,8586	0,3899
LABORATOIRE	667	0,9216	1,0000
OPTICIEN	80	0,8889	1,0000
PHARMACIE	3 910	0,9011	0,9850

Par formule

Segment	n	Rappel	Précision
CONFORT	2 125	0,8556	0,5498
ESSENTIEL	5 580	0,8733	0,5910
PREMIUM	2 381	0,8764	0,6753

Par type de fraude

Type	n	Rappel
ACTE_FICTIF	53	1,0000
DOUBLON	111	**0,2252**
FRACTIONNEMENT	37	0,7838
INCOHERENCE_PROFIL	33	1,0000
LIGNES_NON_PRESCRITES	87	1,0000
ORDONNANCE_EXPIREE	76	1,0000
PRESTATAIRE_RADIE	55	1,0000
QUANTITE_EXCESSIVE	59	0,9153
SUBSTITUTION_PRODUIT	43	1,0000
SURCONSOMMATION	37	1,0000
SURFACTURATION	165	1,0000
UPCODING	82	0,8171

4.3 Lecture

Le rappel global est de 87,0 %, sous l'objectif de 90 %. L'écart est assumé et documenté : le seuil a été arbitré sur le jeu de validation, pas sur le test, pour éviter une fuite de données. Baisser le seuil à 0,20 porterait le rappel à 89 %, au prix de près de 1 000 faux positifs supplémentaires.

Les segments les plus faibles sont identifiables :

- `CABINET_GENERALISTE` : rappel 0,7622 sur 2 518 factures, l'écart le plus important sur un segment suffisamment peuplé. L'explication la plus probable est une activité plus hétérogène (actes courants, volumes élevés), qui dilue le signal ; elle reste à confirmer par une analyse des variables SHAP.
- `TRÈS ÉLEVÉ` : rappel 0,7922 sur 870 factures. La précision est élevée (0,8841), donc le modèle est prudent : il alerte peu, mais juste.
- `30–49` : rappel 0,8465 sur 2 638 factures. L'écart est modéré ; il doit être surveillé, pas conclu.
- `65+` : 0,8889 mais seulement 134 factures. Le résultat n'est pas statistiquement robuste.

Le cas `DOUBLON` est une limite des données, pas du modèle. Sur 909 factures étiquetées `DOUBLON`, seules 12 ont une signature répétée et 14 partagent leur `numero_facture` avec une autre facture. 98 % des cas n'ont aucune duplication observable. Réentraîner ne résoudra pas le problème : il faut une **règle déterministe** sur `numero_facture` à la réception. Les dix règles d'invalidité existent déjà dans `predicare_seed.qualite_donnees`.

4.4 Mesures

Mesure	Effet attendu	État
Décision humaine obligatoire	Empêche un refus automatique	En place
Audit d'équité versionné	Rend les écarts visibles	En place
Règle déterministe `numero_facture`	Couvre `DOUBLON`	À brancher
Surveillance par segment en production	Détecte une dérive d'équité	À ajouter au worker
Seuil par segment	Réduit l'écart, mais risque juridique	Non recommandé sans avis

Mesure	Effet attendu	État
Données supplémentaires généralistes	Améliore le rappel	À planifier
Explication SHAP au gestionnaire	Permet de contester le score	En place

4.5 Risque résiduel

Le risque d'iniquité n'est pas éliminé. Il est **visible, mesuré et encadré** par une décision humaine et un audit versionné. Avant production, il faut définir un seuil d'alerte par segment (par exemple, un écart de rappel de plus de 10 points sur un segment de plus de 500 factures) et l'intégrer au plan de surveillance.

5. Sécurité

5.1 Modèle de menace

Menace (STRIDE)	Scénario	Contrôle	Écart
Usurpation	Vol de jeton, force brute	JWT signé, Argon2id, mot de passe 12 caractères, rate limit 60/min	Pas de MFA
Altération	Injection SQL, prompt injection	SQL lecture seule + liste blanche, filtre, séparation instruction/donnée	Filtre non exhaustif
Répudiation	Nier une décision	`audit.decision_gestionnaire`, `audit.journal`, logs JSON	Connexions non journalisées
Divulgation	Fuite de noms, cache partagé	Chiffrement Fernet, pseudonymes, scope `assure_id`	Sauvegardes non chiffrées
Déni de service	Script sur le RAG	Rate limit Traefik, question limitée à 1 000 caractères, `LIMIT` SQL	Pas de quota par utilisateur
Élévation de privilèges	Admin via API	RBAC 4 rôles, routes admin protégées	Périmètre professionnel trop large

5.2 Authentification et habilitations

Contrôle	Implémentation
Hachage des mots de passe	Argon2id, minimum 12 caractères
Jeton	JWT HS256, expiration, rôle, `assure_id`, `session_id`
Rôles	assuré, professionnel de santé, gestionnaire, administrateur
Filtre assuré	Côté serveur, à partir du jeton, jamais du corps de requête
Routes admin	Permissions dédiées (`seuil:modifier`, `modele:bascule`), contrôle avant handler
Rate limit	60 requêtes/min, burst 120 (Traefik)

Le contrôle d'accès est centralisé dans `packages/predicare-core/src/predicare/rbac.py` et appliqué par des dépendances FastAPI. Une route non annotée est refusée par défaut dans les tests RBAC.

5.3 Protection des données

- **Au repos** : identités chiffrées avec Fernet ; clé dans `.env`, jamais en base ni dans le code. Les factures et prédictions sont pseudonymisées.
- **En transit** : HTTP local sur le réseau Docker ; TLS non terminé sur la passerelle. En production, terminer TLS sur Traefik (ou un LB) et rediriger HTTP vers HTTPS.
- **Sauvegardes** : `pg_dump` compressé, non chiffré. Ajouter `age` ou `gpg` avant écriture, et une clé séparée.
- **Secrets** : `.env` ignoré, `make doctor` vérifie les placeholders. Rotation non automatisée.
- **Logs** : JSON, sans noms ; les identifiants de facture et de prédiction restent des données pseudonymisées.

5.4 Sécurité du RAG

Contrôle	Détail
Filtre d'injection	Motifs déclarés, refus explicite, journalisation
Séparation des rôles	Question dans un bloc `<question>`, instructions système séparées
Longueur	Question limitée (1 000 caractères), historique borné
SQL	Compte `predicare_ro`, transaction read-only, liste blanche, paramètres liés
Périmètre	`assure_id` du jeton, jamais du texte de la question
Cache	Cloisonné par assure, pas de cache pour les questions de suivi
Réponse	Sources citées, extraits, scores de similarité

La barrière qui ne dépend pas du vocabulaire est le **compte SQL en lecture seule** : même si un filtre textuel est contourné, l'agent ne peut pas écrire. Le périmètre de lecture, lui, est tenu par l'injection du `assure_id` du jeton et la liste blanche de requêtes, pas par le rôle.

5.5 Réseau et chaîne d'approvisionnement

- **Réseau `core` interne** : PostgreSQL et Redis ne sont pas publiés sur l'hôte ; seuls les API et la passerelle sont accessibles.
- **Passerelle** : Traefik sans socket Docker, en-têtes de sécurité (CSP, HSTS, nosniff, frame-deny), rate limit, journal d'accès.
- **Images** : tags explicites dans `docker-compose.yml`, lock Python `uv.lock`, CI GitHub Actions.
- **Dépendances** : deux alertes Dependabot modérées ouvertes au 20/10/2026 ; à traiter avant la soutenance.

5.6 Audit et supervision

Élément	Contenu	Preuve
Journal d'audit	acteur, rôle, action, cible, détails, date	`audit.journal`
Décisions	prédiction, décision, commentaire, acteur, date	`audit.decision_gestionnaire`
Modèles	version, artefact, empreinte, métriques, statut	`ml.modele_version`
Dérive	PSI, variables, effectifs, alerte, date	`ml.rapport_derive`
Métriques	latence, erreurs, tokens, coût, cache	Prometheus
Tableaux de bord	Grafana, Superset	`docker-compose.observability.yml`
Workflows	exécutions n8n, erreurs	n8n `execution_entity`

5.7 Preuves de test

Suite	Résultat	Commande
Tests unitaires et d'intégration	**659 passés, 18 ignorés**	`make test`

Suite	Résultat	Commande
Attaques RAG	97 tests, 100 % des attaques déclarées bloquées	`pytest tests/test_rag_attacks.py`
Garde-fous	78 tests	`pytest tests/test_guardrails.py`
SQL	57 tests	`pytest tests/test_sql_tool.py`
RBAC	22 tests	`pytest tests/test_rbac.py`
Chaîne n8n	13/13 vérifications	`make e2e-n8n`
Lint	OK	`make lint`

Les 18 tests ignorés sont les tests e2e et PostgreSQL sans pile démarrée ; ils sont rejoués sur la plate-forme de démonstration.

5.8 Écarts et plan de durcissement

Écart	Risque	Action	Priorité
TLS non terminé	Interception, vol de jeton	Terminer TLS sur Traefik, rediriger HTTP	P0
Sauvegardes non chiffrées	Fuite d'un volume	Chiffrer avec `age`, clé séparée	P0
Professionnel voit toutes les factures	Divulgation	Filtrer par `prestataire_id`	P0
Connexions non journalisées	Répudiation	Écrire un événement `auth.login`	P1
2 alertes Dependabot	Vulnérabilité connue	Mettre à jour les dépendances	P1
Pas de test d'intrusion	Faux sentiment de sécurité	Prestation ou test interne	P1
Rotation de clé	Compromission durable	Procédure + job	P2
Pas de MFA	Vol de mot de passe	TOTP pour admin/gestionnaire	P2
Quota par utilisateur	Abus du LLM	Quota Redis par sujet	P2

6. Cache sémantique et FinOps

6.1 Mécanisme et garde-fous

Le cache sémantique vectorise la question et la compare aux questions déjà vues. Si le cosinus dépasse **0,95**, la réponse est réutilisée sans appeler le LLM. Le cache est en mémoire, dans le processus `api-rag`.

Garde-fous :

- **cloisonnement** : la clé contient `assure_id` ou `user:{subject}` ; deux assurés ne partagent jamais une entrée ;
- **pas de cache pour les questions de suivi** : dès qu'un historique existe, le cache est contourné ; une réponse dépend du contexte de la session ;
- **pas de cache d'échec** : une entrée `succes=False` n'est jamais servie ;
- **pas de cache pour les mutations** : le cache ne sert que la lecture ;
- **durée de vie** : le cache est perdu au redémarrage, ce qui est assumé.

6.2 Mesure

Un test contrôlé a envoyé la même question plusieurs fois. Le premier appel interroge le LLM ; les suivants sont servis par le cache. Les compteurs du service affichent 2 hits et 2 miss, dont un miss antérieur au test.

Indicateur	Valeur	Source
Entrées en cache	2	`/api/rag/cache/stats`
Hits / miss	2 / 2	même
Taux de réutilisation	0,5	même
Latence évitée	10 477,66 ms	même
Appels LLM évités	2	même
Coût évité	0,00064 EUR	même
Coût moyen par hit	0,00032 EUR	calcul
Tokens sur un hit	0	réponse `/api/rag/question`

Le coût évité est calculé à partir du coût des réponses mises en cache ; le service le marque comme **estimation**. Le cache évite le temps d'un appel LLM, mais la latence HTTP résiduelle (routage, sérialisation) reste.

6.3 Modèle de coût

Volume	Sans cache	Avec 30 % de hits	Avec 50 % de hits
1 000 questions/mois	7,68 USD/an	5,38 USD/an	3,84 USD/an
10 000 questions/mois	76,80 USD/an	53,76 USD/an	38,40 USD/an

Le taux de hits dépend de la diversité des questions. Un assistant qui répond à des questions de contrat très variées aura un taux faible ; un assistant qui répète les mêmes questions (remboursement, plafond, délai) aura un taux élevé. Le cache est donc un accélérateur, pas une promesse.

6.4 Limites

- **En mémoire** : perdu au redémarrage, non partagé entre instances.
- **Sémantique** : deux questions proches peuvent avoir des réponses différentes (par exemple, « consultation » vs « consultation spécialiste »). Le seuil 0,95 est conservateur ; le baisser augmente le risque.
- **Données personnelles** : une réponse de cache contient des données de l'assuré. Le cloisonnement est donc une exigence RGPD, pas une optimisation.
- **Pas de cache pour les suivis** : le gain est nul sur les conversations longues, qui sont aussi les plus coûteuses.

6.5 Recommandations

1. Mesurer le taux de hits en production avant de communiquer un gain.
2. Ajouter un quota de tokens par utilisateur pour éviter l'abus.
3. Surveiller `predicare_llm_cost_usd_total` et alerter à 80 % du budget.
4. Réduire `RAG_TOP_K` et `SESSION_MAX_TURNS` avant d'augmenter le cache.
5. Garder le seuil 0,95 tant qu'une évaluation de précision du cache n'a pas été faite.

Annexes

A. Index des preuves

Preuve	Fichier / commande	Date
Métriques du modèle	`reports/modele_v2.md`	2026-10-19
Audit d'équité	`reports/equite_v2.md`	2026-10-19
Qualité des données	`reports/qualite_donnees_phase1_4.md`	2026-10-19
Évaluation RAG (5 exécutions)	`reports/eval_rag_2026-10-19_*.json`	2026-10-19
Coût RAG	`apps/api-rag/README.md`, `/api/rag/question`	2026-10-20
Cache	`GET /api/rag/cache/stats`	2026-10-20
Dérive	`GET /api/inference/derive`, `ml.rapport_derive`	2026-10-20
Tests	`make test` : 659 passés, 18 ignorés	2026-10-20
Lint	`make lint` : OK	2026-10-20
n8n	`make e2e-n8n` : 13/13	2026-10-20
Base	110 Mo, 84 608 factures, 5 528 prédictions	2026-10-20
Sauvegarde	12 659 763 octets compressés	2026-10-20

B. Hypothèses et taux

Hypothèse	Valeur	Justification
Taux EUR → MGA	5 000	Convention de travail, à actualiser
Prix VPS 4 vCPU / 8 Go	8,49 €/mois HT	Comparateur public, oct. 2026
Prix VPS stress	12,00 €/mois HT	Marge pour les overlays et les sauvegardes
Coût stockage objet	0,01 €/Go/mois	Ordre de grandeur
Coût faux positif	3 000 MGA	Coût d'un contrôle
Coût faux négatif	30 000 MGA	Fraude non détectée
Taux de fraude du test	8,7 %	878 / 10 086
Volume annuel	84 593 factures	Jeu de données

Références externes

- Règlement (UE) 2016/679 du 27 avril 2016 (RGPD).
- Règlement (UE) 2024/1689 du 13 juin 2024 (AI Act).
- Tarif VPS : CostGoat, *Hetzner Cloud VPS Pricing Calculator (Oct 2026)*, https://costgoat.com/pricing/hetzner, consulté le 20 octobre 2026.
- Tarifs LLM : valeurs configurées dans `packages/predicare-core/src/predicare/config.py` (0,15 USD par million en entrée, 0,60 USD par million en sortie).

C. Glossaire

Terme	Définition
AIPD / DPIA	Analyse d’impact relative à la protection des données
AI Act	Règlement (UE) 2024/1689 sur l’intelligence artificielle
GPAI	Modèle d’IA à usage général
MGA	Ariary malgache
PSI	Population Stability Index, mesure de dérive
RAG	Retrieval-Augmented Generation, génération augmentée par récupération
SHAP	Contribution de chaque variable au score
TCO	Total Cost of Ownership, coût total de possession
TP / FP / FN / TN	Vrais positifs, faux positifs, faux négatifs, vrais négatifs

D. Checklist pour le jury

1. **Le modèle est-il précis ?** ROC-AUC 0,9500, rappel 87,0 %, précision 59,7 % au seuil 0,2876 ; le rappel est sous l’objectif de 90 %, assumé.
2. **Les alertes sont-elles explicables ?** Oui : SHAP par facture, lisible par le gestionnaire, et journalisé.
3. **Le système décide-t-il seul ?** Non : le gestionnaire valide, rejette ou demande une pièce ; la décision est auditée.
4. **Les données personnelles sont-elles protégées ?** Noms chiffrés, pseudonymes partout ailleurs, cache cloisonné, SQL en lecture seule.
5. **Le RAG est-il fiable ?** 30/30 en fidélité, 20/20 en citation, 26/26 en exactitude ; p95 6,19 s, au-dessus de la cible de 5 s.
6. **Le RAG résiste-t-il aux attaques ?** 97 tests, 100 % des attaques déclarées bloquées ; la barrière finale est le compte SQL en lecture seule.
7. **Combien ça coûte ?** 109 €/an en base, 391 €/an en stress conservateur ; les tokens sont minoritaires, l’infrastructure domine.
8. **Combien ça rapporte ?** 22,66 M MGA sur le jeu de test, 190 M MGA/an en projection ; 41,6× à 348,8× le TCO.
9. **Le système est-il équitable ?** Les écarts sont mesurés et publiés ; `CABINET_GENERALISTE` et `TRÈS ÉLEVÉ` sont les segments à surveiller ; `DOUBLON` relève d’une règle déterministe.
10. **Est-il conforme à l’AI Act ?** Conforme par conception sur la supervision humaine, l’explicabilité, la journalisation et les tests ; pas certifié : évaluation de conformité, CE, enregistrement et QMS restent à produire.